

CyClaw authentication settings and how-tos

Two different credentials exist. Mixing them is the usual 401. This guide is from live origin/main, not from memory.

Fact	Value
Checkout SHA	57e052ed9222d42a20b95ceb4dec71d21e169f57
Authority	config.yaml + gate_auth.py + utils/authn*.py win over this PDF
Shipped auth.enabled	false (quoted YAML "true" is also OFF)
Shipped api.tls.enabled	false
Bind	127.0.0.1:8787 (harness 8790)
Graph (unrelated)	12 nodes; auth is not a graph node

Fable rule used here: every flag and number was re-read from the tree. If a later commit moves a default, re-read config.yaml. This PDF is not a substitute for the files.

Contents

1. The two systems (do not mix)
2. Shipped posture
3. Stages 1-6 (all landed, still opt-in)
4. Config keys and store
5. Roles, routes, cookies
6. How-to: turn on per-user auth
7. How-to: cyclaw-user CLI
8. How-to: TLS for LAN
9. How-to: CYCLAW_API_KEY (Soul / ops)
10. Console slash commands and 401 copy
11. What this is not
12. Sources

1. The two systems (do not mix)

CyClaw has a shared operator secret and an optional per-user identity layer. They are both real authentication. They are not interchangeable. The terminal key box is the ops secret. The login panel is per-user auth. POST /query uses neither while auth.enabled is false, and uses the session cookie (or a named device token) when auth.enabled is the literal boolean true.

System	Config	What it gates	Console
Ops secret	env CYCLAW_API_KEY	/soul/*, /ops/*, GET /audit/summary (require_api_key). Fail-closed if unset.	#apiKeyInput sends Authorization: Bearer. Never POST /query.
Per-user auth	auth.enabled (default false)	/auth/* always registered (503 when off). Stage 3 attaches require_session_or_token to POST /query only when enabled is literal true.	Set admin password, then login. Cookie cyclaw_session + header X-CyClaw-CSRF.

Trap: pasting CYCLAW_API_KEY into the browser cannot configure the server process. require_api_key compares against os.environ. If the gateway started without the env var you get 401 "Soul mutation disabled: CYCLAW_API_KEY not set" even with a Bearer. Trap: once auth is on, sending that same ops key on /query is treated as a device token and 401s. terminal.js queryHeaders() is the correct /query path.

2. Shipped posture

- auth.enabled: false. /query, /, /health, /static/* have no session gate.
- /auth/login, /auth/logout, /auth/whoami, /auth/setup-status exist anyway. Disabled returns 503, never 404, so route presence does not disclose the flag.
- api.host 127.0.0.1, api.port 8787, api.tls.enabled false.
- Quoted YAML "true" is OFF for both auth.enabled and tls.enabled.
- app.mode hybrid and both LLM providers enabled is I3 (per-query confirm), not this auth layer.

3. Stages 1-6 (all landed, still opt-in)

docs/AUTHENTICATION_DESIGN.md status is "all six stages landed". Enabling still changes behavior; CI and default installs leave the flags false.

Stage	What landed	PR
1	utils/authn.py -- script hash/verify, password policy, lockout arithmetic. No HTTP.	#829
2	AuthManager, SQLite/Postgres store, sessions, device tokens, gate_auth.py /auth/*.	#830
3	require_session_or_token on POST /query when auth.enabled is literal true. Console login.	#940
4	api.tls wired in gate._serve; missing certs fail closed; cyclaw-gen-cert.	#940
5	Loopback bind guard re-keyed: non-loopback allowed only with auth + TLS + /query actually gated.	#825
6	Roles admin / operator / audit, HTTP user admin, Users + Audit panels.	#940

4. Config keys and store

Key	Shipped	Notes
auth.enabled	false	Literal boolean true only. Participates in bind guard.
auth.db_path	data/auth/cyclaw_auth.db	SQLite, repo-root relative.
auth.database_url / CYCLAW_AUTH_DB_URL	unset	Postgres. Do not reuse personality CYCLAW_DB_URL.
auth.session.idle_timeout_sec	43200	12h rolling; resets on valid use.
auth.session.absolute_timeout_sec	604800	7d. Session dies at whichever limit hits first.
api.tls.enabled	false	Marks cookie Secure; requires readable certfile/keyfile at boot.
api.tls.certfile / keyfile	data/tls/cert.pem / key.pem	cyclaw-gen-cert defaults.
api.host / port	127.0.0.1 / 8787	Loopback by design.

Password policy (utils/authn.py): minimum 12 characters, maximum 1024. Length only; no composition rule. Hash is script. Bootstrap user is username admin with an unusable pending\$ hash until bootstrap-password or cyclaw-user passwd admin. Lockout: 5 consecutive failures then exponential delay, ceiling 900s (15 min), not a permanent lock.

5. Roles, routes, cookies

Role	Can query	Users panel	Audit
admin	yes	yes	yes
operator	yes	yes	no
audit	no (AUTH_ROLE_DENIED on /query)	no	yes

Cookie name cyclaw_session (HttpOnly, SameSite=strict, Secure when TLS on). CSRF header X-CyClaw-CSRF (code: x-cyclaw-csrf). Session id and device tokens are hashed at rest (utils/authn.hash_token); plaintext is shown once at mint. GET /health stays unauthenticated.

Route	When auth off	When auth on
POST /query	Open (plus rate limit / sanitizer).	Session cookie or named device Bearer. Not the ops API key.
GET /auth/whoami	503	Session or device token; returns username + role.
POST /auth/login	503	Issues cookie + csrf_token.
POST /auth/bootstrap-password	503	Loopback only (AUTH_LOOPBACK_ONLY). First admin password.
GET /auth/setup-status	503	{needs_password, username} -- no hashes.
GET /audit/summary	Ops API key (require_api_key).	Same ops key. Session audit is GET /auth/audit/summary (admin/audit).
/soul/* /ops/*	Ops API key, fail-closed if env unset.	Still ops API key. Identity does not replace it.

6. How-to: turn on per-user auth

Do this on loopback first. Do not bind off 127.0.0.1 until TLS is also on with real cert files. Docker CMD bypasses gate._serve TLS wiring; python gate.py / cyclaw-server is the path that honors api.tls.

Step 1 -- edit config.yaml

```
auth:
  enabled: true          # literal boolean; not the string true
  db_path: "data/auth/cyclaw_auth.db"
  session:
    idle_timeout_sec: 43200
    absolute_timeout_sec: 604800
```

Step 2 -- restart the gateway so AuthManager is constructed. No account exists until the flag is on; nothing is created automatically except the pending admin placeholder.

Step 3 -- set the first admin password from this machine (loopback).

- Open `http://127.0.0.1:8787`. The UI shows Set admin password when GET `/auth/setup-status` reports `needs_password`.
- POST `/auth/bootstrap-password` with a password of at least 12 characters. Same-origin + loopback peer required.
- Or locally: `cyclaw-user passwd admin (getpass, not echoed)`.
- Harness twin: GET `/api/auth/setup-status` and POST `/api/auth/bootstrap-password` on `:8790`.

Step 4 -- log in. POST `/auth/login` returns `csrf_token`; cookie is set. Later mutating `/auth/*` calls need X-CyClaw-CSRF. Logout: POST `/auth/logout`.

7. How-to: cyclaw-user CLI

Local-only argparse. No HTTP. After install, the console script is `cyclaw-user`. Equivalent: `python -m utils.authn_cli`. Default `--config config.yaml` (repo-rooted, not cwd).

```
cyclaw-user add alice --role operator      # omit --password to be prompted
cyclaw-user list
cyclaw-user role alice admin
cyclaw-user disable alice
cyclaw-user enable alice
cyclaw-user passwd alice
cyclaw-user token create alice laptop
cyclaw-user token list alice
cyclaw-user token revoke alice laptop
```

token create prints the secret once: "Save this token now -- it will not be shown again." That Bearer is a device token for `/query` when auth is on. It is not `CYCLAW_API_KEY`. Exit 0 ok, 2 operation failed, 3 config/store problem. Default role on add is operator.

8. How-to: TLS for LAN

Non-loopback bind is allowed only when authentication is enabled AND TLS is enabled AND `/query` actually carries the credential dependency. Enabling TLS without readable cert files fails closed at boot (no plaintext socket with Secure cookies).

```
cyclaw-gen-cert
# or:
python -m utils.gen_cert --certfile data/tls/cert.pem --keyfile data/tls/key.pem
```

```
# options: --hostname (default: this machine), --days 825
# needs openssl (Git for windows usr\bin\openssl.exe is fine)
```

Then set `api.tls.enabled: true` (literal boolean) and restart via `python gate.py` or `cyclaw-server`. Browsers will warn on the self-signed cert; that is expected.

9. How-to: CYCLAW_API_KEY (Soul / ops)

This secret is independent of `auth.enabled`. Soul mutations and `/ops/*` stay 401 until the gateway process has the env var. `security.api_key_optional` is a loopback-peer escape hatch and ships false.

- macOS: `macos/setup-cyclaw-keys.sh` writes `~/CyClaw/.env` (`chmod 600`) and Keychain. New shells source the rc block.
- `invoke-cyclaw.sh` sources `$HOME/.CyClaw/.env` (else repo `.env`) only if `CYCLAW_API_KEY` is still empty, refuses `xtrace`, and skips files that are not mode 600 or 400.
- Then paste the same value into the terminal Soul/ops field (placeholder: `CYCLAW_API_KEY (Soul / ops)`). Memory only; not `localStorage`.
- If the server was started without the env, the console now says so. Restart after sourcing the `dotenv`; typing in the box cannot set `os.environ`.

10. Console slash commands and 401 copy

`terminal.js` intercepts `/users`, `/admin`, `/audit`, `/help` with `toLocaleLowerCase('en-US')` so Turkish locale I does not break `/AUDIT`. Other `/text` is a RAG query. `/help` is not a harness dispatcher.

- `/audit` with a typed ops key: `GET /audit/summary + authHeaders()`.
- `/audit` without a key: `GET /auth/audit/summary` (needs a session; 503 when auth is off).
- `/users` and `/admin` open the Users panel only if the role button is shown.
- 401 "CYCLAW_API_KEY not set" vs "Invalid or missing API key" are mapped in `describeApikeyError`.

11. What this is not

Gate	Why it is different
I3 hybrid confirm	<code>user_confirmed_online</code> + provider enabled + hybrid mode. Not a login.
Soul mutation reason	I5 human reason + injection scan + atomic write. Still needs ops API key.
Telegram T3 /online	Private-chat one-shot hybrid consent. Channel is OOB (I6).
Harness <code>/api/agent/*</code>	Bearer+CSRF on the coding console; not <code>gate.py /auth</code> .

12. Sources (re-read if this PDF ages)

- `config.yaml` `auth:` and `api.tls:` blocks
- `gate_auth.py` (cookie/header names, 503-when-off, loopback bootstrap)
- `gate.py` `require_api_key` and `bind guard`
- `utils/authn.py`, `utils/authn_manager.py`, `utils/authn_cli.py`, `utils/gen_cert.py`

- docs/AUTHENTICATION_DESIGN.md (stages; some early "console sends Bearer on /query" sentences are stale vs terminal.js queryHeaders())
- static/terminal.js authHeaders / queryHeaders / slash intercepts

Verified against origin/main 57e052ed9222d42a20b95ceb4dec71d21e169f57. Not verified in this PDF build: a live login against a running gateway on this host.